Usable Privacy and Security

Introduction to Privacy

Dr. Oshrat Ayalon, Spring 2026

Agenda

- What is privacy?
  - Privacy theories
- Privacy decision making and behavior
- Privacy laws around the world
- Measuring privacy

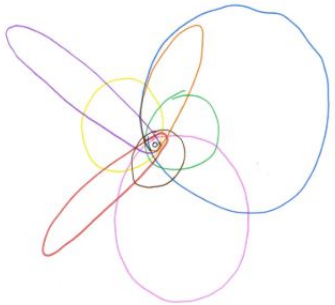


Fig. 6. "Privacy, to me, is control over the compartmentalization and overlap of information for/between distinct audiences." By Josh, age 32

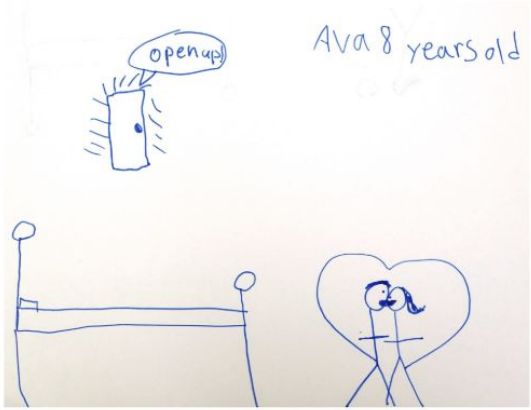


Fig. 17. "Parents kissing behind a closed door." By Ava, age 8

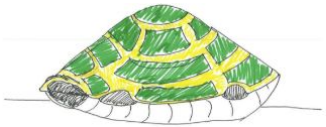


Fig. 63. "It's a turtle huddled up inside its shell." By John

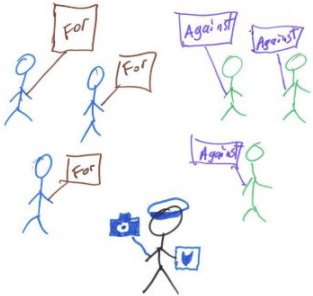
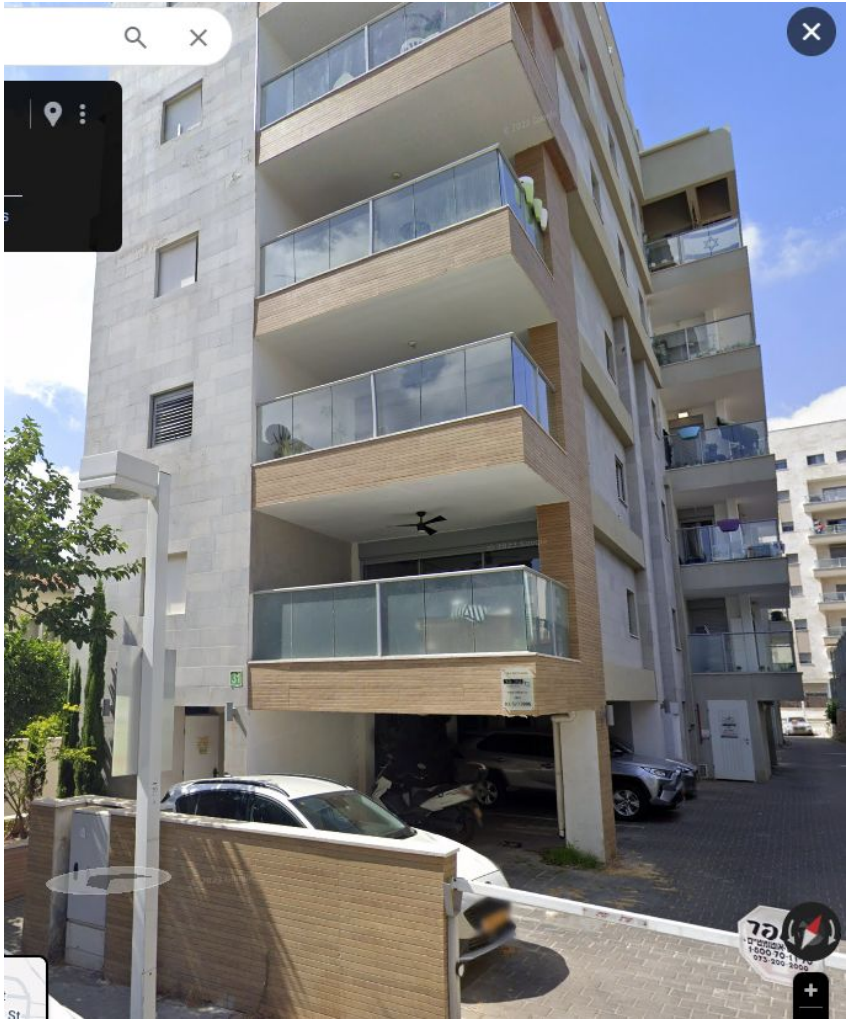


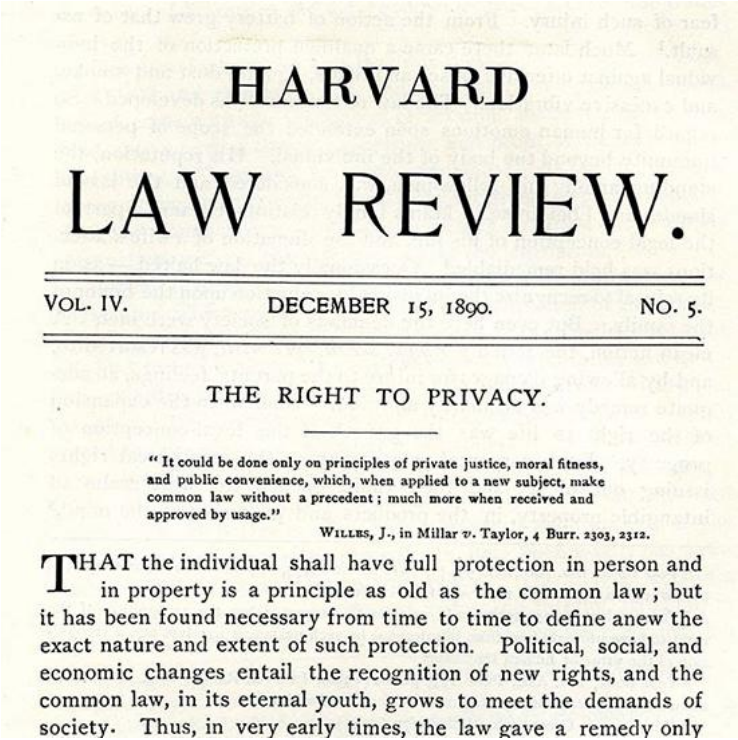
Fig. 30. "People should be able to express their views without surveillance & infiltration by the police." By anonymous, age "old"

"What does privacy mean to you?"
Oates et al., 2018, Proceedings on Privacy Enhancing Technologies



Privacy theories

Warren and Brandeis (1890)



HARVARD

LAW REVIEW.

VOL. IV. DECEMBER 15, 1890. NO. 5.

THE RIGHT TO PRIVACY.

"It could be done only on principles of private justice, moral fitness, and public convenience, which, when applied to a new subject, make common law without a precedent; much more when received and approved by usage."

WILLES, J., in Millar v. Taylor, 4 Burr. 2303, 2312.

THAT the individual shall have full protection in person and in property is a principle as old as the common law; but it has been found necessary from time to time to define anew the exact nature and extent of such protection. Political, social, and economic changes entail the recognition of new rights, and the common law, in its eternal youth, grows to meet the demands of society. Thus, in very early times, the law gave a remedy only

Warren and Brandeis's Inspiration

- Photographs, photos without consent
- Gossip pages about high society

Warren and Brandeis's Argument

THAT the individual shall have full protection in person and in property is a principle as old as the common law; but it has been found necessary from time to time to define anew the exact nature and extent of such protection. Political, social, and

- Libel and slander are insufficient in considering **only damage to reputation**
  - הוצאת דיבה, לשון הרע
- Considers property rights
- The right to **prevent**, rather than profit from, publication
- "The right to be let alone"
- Excludes topics of general interest

Is Being “Let Alone” Sufficient?

The Washington Post
Democracy Dies in Darkness

Apple employee detained by U.S. customs agents after declining to unlock phone, laptop

By Hamza Shaban

April 3, 2019 at 4:48 p.m. EDT

Privacy as Control / Secrecy (1967)

"Privacy is the claim of individuals, groups or institutions to **determine for themselves** when, how, and to what extent information about them is communicated to others."

- Individuals have right to control, edit, manage, and delete info about themselves and control how that information is communicated

– Alan Westin, Privacy and Freedom, 1967

Westin’s segmentation is also very focused on limiting access

- Is access limitation sufficient?
- Individuals sometimes prefer to be let alone, yet sometimes want to be social
  - Is privacy only gained by “**social withdrawal**” ?

Privacy Regulation Theory (1975)

- Irwin Altman (social psychology)
- Dialectic and dynamic process of boundary regulation
  - Dialects: openness and closeness
  - Dynamics: desired privacy level
  - Continuous movement on a continuum
- Goal: optimum balance of privacy and social interaction

Privacy as Contextual Integrity (2004)

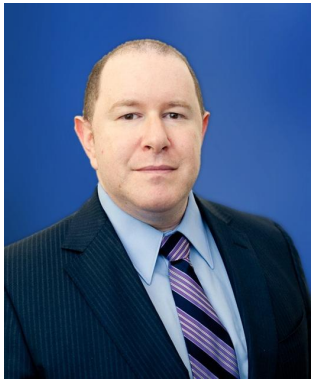
- Helen Nissenbaum (philosophy)
- “Contextual integrity ties adequate protection for privacy to norms of specific contexts, demanding that information gathering and dissemination be appropriate to that context.”

Privacy as Contextual Integrity

- Appropriate flows of information
- Appropriate flows conform to contextual information norms
- Norms refer to the data subject, sender, recipient, information type, and transmission principle
- Conceptions of privacy evolve over time and are grounded in ethics

Daniel Solove's Pluralistic Conceptions

- Some data isn't "sensitive," but its collection and use impact privacy
  - Aggregation, Secondary use
  - Impact power relationships - "The classic example is law enforcement officials having too much power, which can alter the way people engage in their activities."
- Solove's privacy taxonomy
  - Information collection → Surveillance
  - Information processing → Exclusion
  - Information dissemination → Blackmail
  - Invasion → Intrusion



Privacy decision making and behavior

Important terms

- Chilling effect: discouragement of exercising a legitimate right
- Privacy paradox: behaviors are inconsistent with concerns - gets its own slide
- Privacy by design: consider privacy throughout the lifecycle of a product
- Secondary use: those other than the intended purpose

Privacy Paradox

- What is it?
  - People express privacy preferences but do something else
- Why?
  - Incomplete information and uncertainty
  - Bounded rationality – decision heuristics and biases
  - Manipulation of privacy behavior (dark patterns – intentional or unintentional)
  - "… privacy paradox is a **myth** created by faulty logic. The **behavior** involved in privacy paradox studies involves people making decisions about risk in **very specific contexts**. In contrast, people's **attitudes** about their privacy concerns or how much they value privacy are **much more general** in nature." –Solove

“I’ve got nothing to Hide” – Daniel Solove

In May 2006, *USA Today* broke the story that the NSA had obtained customer records from several major phone companies and was analyzing them to identify potential terrorists.[6] The telephone call database is reported to be the “largest database ever assembled in the world.”[7] In June 2006, the *New York Times* stated that the U.S. government had been accessing bank records from the Society for Worldwide Interbank Financial Transactions (SWIFT), which handles financial transactions for thousands of banks around the world.[8] Many people responded with outrage at these announcements, but many others did not perceive much of a problem. The reason for their lack of concern, they explained, was because: “I’ve got nothing to hide.”[9]

The argument that no privacy problem exists if a person has nothing to hide is frequently made in connection with many privacy issues. When the government engages in surveillance, many people believe that there is no threat to privacy unless the government uncovers unlawful activity, in which case a person has no legitimate justification to claim that it remain private. Thus, if an individual engages only in legal activity, she has nothing to worry about. When it comes to the government collecting and analyzing personal information, many people contend that a privacy harm exists only if skeletons in the closet are revealed. For example, suppose the government examines one’s telephone records and finds out that a person made calls to her parents, a friend in Canada, a video store, and a pizza delivery place. “So what?,” that person might say. “I’m not embarrassed or humiliated by this information. If anybody asks me, I’ll gladly tell them where I shop. I have nothing to hide.”

Chilling effect?

Responses to “Nothing to Hide” (Solove’s blog)

I encountered the nothing to hide argument so frequently in news interviews, discussions, and the like, that I decided to blog about the issue. I asked the readers of my blog, *Concurring Opinions*, whether there are good responses to the nothing to hide argument.[21] I received a torrent of comments to my post:

- My response is “So do you have curtains?” or “Can I see your credit card bills for the last year?”[22]
- So my response to the “If you have nothing to hide . . .” argument is simply, “I don’t need to justify my position. You need to justify yours. Come back with a warrant.”[23]
- I don’t have anything to hide. But I don’t have anything I feel like showing you, either.[24]
- If you have nothing to hide, then you don’t have a life.[25]
- Show me yours and I’ll show you mine.[26]
- It’s not about having anything to hide, it’s about things not being anyone else’s business.[27]
- Bottom line, Joe Stalin would [have] loved it. Why should anyone have to say more?[28]

https://teachprivacy.com/is-there-a-good-response-to-the-nothing-to-hide-argument/

What is your response?

Privacy laws

How privacy is protected

Laws, self regulation, technology

- Notice and access
- Control over collection, use, deletion, sharing
- Collection limitation
- Use limitation
- Security and accountability

Privacy laws around the world

- US has mostly sector-specific laws, minimal protections, often referred to as “patchwork quilt”
  - No explicit constitutional right to privacy or general privacy law
  - Some privacy rights inferred from constitution
  - Narrow regulations for health, credit, education, videos, children
  - Some state and local laws - California Consumer Privacy Act (CCPA) and California Privacy Rights Act (CPRA)
- Europe has comprehensive privacy laws like General Data Protection Regulation Act (GDPR) and data protection commissioners in every country

חוק הגנת הפרטיות, תשמ"א-1981

פגיעה בפרטיות היא אחת מאלה:

(1) בילוש או התחקות אחרי אדם, העלולים להטרידו, או הטרדה אחרת;

(2) האזנה האסורה על פי חוק;

(3) צילום אדם כשהוא ברשות היחיד;

(4) פרסום תצלומו של אדם ברבים בנסיבות שבהן עלול הפרסום להשפילו או לבזותו;

(4א) פרסום תצלומו של נפגע ברבים שצולם בזמן הפגיעה או סמוך לאחריה באופן שניתן לזהותו ובנסיבות שבהן עלול הפרסום להביאו במבוכה, למעט פרסום תצלום בלא השהיות בין רגע הצילום לרגע השידור בפועל שאינו חורג מהסביר באותן נסיבות; לעניין זה, "נפגע" – מי שסבל מפגיעה גופנית או נפשית עקב אירוע פתאומי ושפגיעתו ניכרת לעין;

(5) העתקת תוכן של מכתב או כתב אחר שלא נועד לפרסום, או שימוש בתכנו, בלי רשות מאת הנמען או הכותב, והכל אם אין הכתב בעל ערך היסטורי ולא עברו חמש עשרה שנים ממועד כתיבתו; לענין זה, "כתב" – לרבות מסר אלקטרוני כהגדרתו בחוק חתימה אלקטרונית, התשס"א–2001;

(6) שימוש בשם אדם, בכינויו, בתמונתו או בקולו, לשם ריווח;

(7) הפרה של חובת סודיות שנקבעה בדין לגבי עניניו הפרטיים של אדם;

(8) הפרה של חובת סודיות לגבי עניניו הפרטיים של אדם, שנקבעה בהסכם מפורש או משתמע;

(9) שימוש בידיעה על עניניו הפרטיים של אדם או מסירתה לאחר, שלא למטרה שלשמה נמסרה;

(10) פרסומו או מסירתו של דבר שהושג בדרך פגיעה בפרטיות לפי פסקאות (1) עד (7) או (9);

(11) פרסומו של ענין הנוגע לצנעת חייו האישיים של אדם, לרבות עברו המיני, או למצב בריאותו, או להתנהגותו ברשות היחיד.

תיקון 13 לחוק להגנת הפרטיות

- Digital data explicitly recognized as personal data
- Shift from ex-ante bureaucracy to internal responsibility
- Real enforcement powers and financial sanctions
- Privacy becomes an organizational and managerial responsibility

Regulatory shift, not merely a legal update

במדריך זה נסקור את עיקרי ההסדרים הקבועים בתיקון מס' 13:

- עיגון בחוק של מעמד הרשות להגנת הפרטיות, ושל החלטת הממשלה בדבר עצמאות הרשות ותפקידיה.
- עדכון כלל ההגדרות המהותיות בחוק והתאמתן להתפתחויות הטכנולוגיות, החברתיות והמשקיות ולהסדרים הקיימים בחקיקה מודרנית של הגנת הפרטיות במדינות מובילות.
- קביעת חובת מינוי ממונה על הגנת הפרטיות (DPO) בכלל הגופים הציבוריים ובשורה ארוכה של חברות וארגונים במגזר הפרטי.
- צמצום משמעותי של חובת רישום מאגרי מידע דיגיטליים והחלפתה בחובת הודעה לרשות על מאגרים גדולים ורגישים.
- קביעת איסור גורף על עיבוד מידע אישי שנאסף באופן לא חוקי ואיסור על עיבוד מידע ללא הרשאה מאת בעל השליטה במאגר.
- קביעת סנקציות של עיצומים כספיים בסכומים משמעותיים (עד מיליוני ש"ח בגין כל הפרה) בשל הפרת הוראות החוק, התקנות בתחום אבטחת המידע והתקנות הנוגעות למאגרים בהם קיים מידע אישי שהועבר לישראל מהאיחוד האירופי.
- קביעת עבירות פליליות חדשות במאגרי מידע.
- עיגון סמכותה של הרשות להגנת הפרטיות לפנות לבית המשפט לקבלת צו להפסקת עיבוד מידע אישי במאגר, לרבות מחיקת מידע.
- עיגון בחוק של סמכויות האכיפה הפלילית של הרשות (ניתנו קודם לכן בהסמכה של השר לביטחון לאומי).
- הרחבת סמכות בתי המשפט לפסוק פיצויים ללא הוכחת נזק בגין הפרת החובות הקבועות בחוק.
- ביטול ההתיישנות המקוצרת בתביעות אזרחיות בגין פגיעה בפרטיות והפרות של החוק.
- הסדר בדבר מתן חוות דעת מקדמית מטעם הרשות בנוגע לעמידת מאגר המידע בדרישות החוק.
- קביעת הסדר פיקוח מיוחד בתחום הפרטיות בגופים ביטחוניים.

מקור: הרשות להגנת הפרטיות

Privacy laws require usability

- Clear and plain language
- Concise, transparent, intelligible, and easily accessible
- Clear and conspicuous
- Easy to find, read, and use notices and choices
  - Use of data
  - Access data that organization has collected
  - Request data deletion

Designer Dima Yarovinsky visualizes lengthy "terms of service" agreements from popular social apps—including Facebook, Instagram, Snapchat, and Tinder—in his project, titled *I Agree*.

"ONLY IN SOME FANTASY WORLD

do users actually read these notices and understand their implications before clicking to indicate their consent"

— President's Council of Advisors on Science and Technology, *Big Data and Privacy* May 2014

Privacy Icons

http://www.azarask.in/blog/post/privacy-icons/ *2010*

Measuring Privacy

Approaches

- Ask respondents directly how concerned they are about privacy
  - In general
  - In specific scenarios or settings
- Ask respondents how concerned they are about certain practices (without mentioning privacy)
  - Ask respondents how much they engage in privacy-enhancing practices
- Or observe how much they protect vs disclose in an experiment

Sören Breibusch, 2013, Guide to measuring privacy concern: Review of survey and observational instruments, Int. J.Human-ComputerStudies71(2013)1133–1143. https://doi.org/10.1016/j.ijhcs.2013.09.002

Internet Users Information Privacy Concerns (IUIPC)

- 10-item, 7-point scale
- From strongly disagree to strongly agree
- 3 sections:
  - Control – how important they think it is to control how their data is used
  - Awareness – how important they think it is to be aware of how their data is used
  - Collection – level of concern about data collection

strongly disagree	○	○	○	○	○	○	○	strongly agree

Malhotra, N.K., Kim, S.S., Agarwal,J., 2004. Internet users' information privacy concerns (IUIPC): the construct, the scale, and a causal model. Information Systems Research15(4), 336–355.

e.g. IUIPC control scale

1. Consumer online privacy is really a matter of consumers' right to exercise control and autonomy over decisions about how their information is collected, used, and shared.

2. Consumer control of personal information lies at the heart of consumer privacy.

3. I believe that online privacy is invaded when control is lost or unwillingly reduced as a result of a marketing transaction.

Privacy in the real world?

"Privacy is not for me, it's for those rich women": Performative Privacy Practices on Mobile Phones by Women in South Asia

Nithya Sambasivan, Garen Checkley, Amna Batool[#], Nova Ahmed[*], David Nemer[+], Laura Sanely Gaytán-Lugo[Ω], Tara Matthews[Ψ], Sunny Consolvo, and Elizabeth Churchill

Google Inc., Mountain View, CA, USA,
{nithyasamba, garen, sconsolvo}@google.com, churchill@acm.org
[#] Information Technology University, Pakistan
batool.amna@itu.edu.pk
[*] North South University, Bangladesh
nova.ahmed@northsouth.edu
[+] University of Kentucky, USA
david.nemer@uky.edu
[Ω] Universidad de Colima, Mexico
laura@ucol.mx
[Ψ] Independent Researcher
taramatthews@gmail.com

ABSTRACT

Women in South Asian own fewer personal devices like laptops and phones than women elsewhere in the world. Further, cultural expectations dictate that they should share mobile phones with family members and that their digital activities be open to scrutiny by family members. In this paper, we report on a qualitative study conducted in India, Pakistan, and Bangladesh about how women perceive, manage, and control their personal privacy on shared phones. We describe a set of five performative practices our

including India, Pakistan and Bangladesh). Here, women are 26% less likely to own a mobile phone compared to men [17]. Twenty-nine percent of South Asian women regularly borrow a phone [16]. Even when phones are individually owned—*i.e.*, in the possession of a user for a majority of the time—women in many South Asian contexts face cultural expectations to share their devices and digital activities. For example, in a survey conducted by GSMA, men, and sometimes women too, found it acceptable for a husband to check his wife's digital activity on her phone [16].

Research Questions/Goals

- How do users deal with privacy with shared devices?
  - Prior work focused on families, co-workers, friends and strangers
  - Not much on social or power-based relationships, e.g., based on cultural expectations
- How do women in South Asia perceive, manage and control their privacy on shared mobile phones?
- How are social expectations of women fulfilled through technological and social affordances?

Methodology

- Focus groups
  - Qualitative data based on discussions
- 199 Women
  - Recruited from India, Pakistan, and Bangladesh

Analysis

- Interviews conducted in local language and translated into English
  - <Translation can be an issue in some research>

- Inductive analysis over raw interview material
  - Codebook with with two-level themes
  - Indian codebook first, and then iterated with Bangladesh and Pakistan

C. Codebook

Top-level category	Definition	Codes
Identity	Identity management of the user, including profiles, self-presentation and settings	Identity management Reputation management Family feedback loops
Co-located privacy	Considerations and management of privacy on shared, mediated or monitored devices	Family sharing Mediation Monitoring Views on privacy Phone locks App locks Micro deletions History deletions Private modes VPN Avoidance Subversion Sensitive content or activities
Access	Ability to use a technology at will, including time, location and social factors	Onboarding Motivations for access Pressures and concerns Money Time Mobility Social perception of access Online activities Fears Mitigation practices Myths of Internet
Online privacy	Considerations and management of privacy on apps, websites and services	Safety concerns Safety practices Information disclosure App-specific privacy models Privacy settings Privacy affordances Privacy violations

Why so much device sharing for women?

In our study, cultural norms for women were one of the major factors that led to phone sharing (also seen in [3,44]). Participants experienced a cultural expectation that they, as women, would share their devices with social relations. In practice, this could involve multiple onlookers as they used their device, having their device passed between multiple people, or using a device that was primarily shared in nature. Since women are typically viewed as the caregivers, participants often reported that their children used their phones to play games or watch videos. Note that this cultural expectation of sharing did not end with phones; participants were also expected to share personal belongings like jewelry, savings, and *saris* (clothing) with other family members.

Other factors also motivated device sharing. While access to a phone was not a barrier in our study (phone ownership was a criterion for participation), the high cost of mobile data sometimes led to shared use. In most of the cases, sharing was reported to be a

But not for men

"My kids don't touch the father's phone. They only use mine all the time. They are scared of him....my daughter broke my husband's phone and got a lot of beatings. She only uses mine. So I have an app lock on my phone."

Privacy practice

Mediation

While some men enabled female relatives to access technology, this practice was also restrictive in that it required women to rely on others for access. As Zeenat (a small business owner, 30 to 35-year old in Lahore, Pakistan) described, she depended on her husband each time she logged in to social media:

"My husband created my Facebook account and he didn't enter my complete information. Because I didn't know how to create a profile, I asked him to create it for me. Now every time I want to use it, he logs in for me."

Monitoring

In some cases, monitoring was viewed as coercive. In Bangladesh, two (out of 5 whose husbands worked abroad) participants reported that their husbands installed tracking tools on their phones to monitor their phone activities. Aysha (a 25 to 30-year old domestic worker) reported feeling upset when her husband first mentioned putting spyware on her phone (it is unclear if he actually did so), but she has now found ways to deal with the monitoring. She explained,

"When I call my mother or make personal calls, I borrow my employer's phone."

Notion of privacy

In contrast to the verbal dissociation of the concept of privacy, *all* participants in our study—no matter their SES background—employed strategies and techniques that the usable security and privacy community would likely call safeguarding and controlling their 'privacy' on their devices. While many of the lower to middle SES participants did not think of these practices as privacy-related, the practices were intentional steps taken to protect device activities and content from being revealed to co-located household members. The higher SES participants did associate these practices with the concept of privacy.

Privacy practices

Phone Lock	App Lock	Aggregate & Entity deletions	Private modes	Avoidance
To prevent misuse by strangers or in case of theft	To secure specific content or apps from kids, family or friends	To remove individual content or queries, or delete history to prevent social judgement while sharing.	To explicitly entering a mode before sensitive activities.	To not do something around family or in public, or avoid an app completely
Challenges: - People around the user can figure out pins	*Challenges:* - People around the user can figure out pins. - Lock presence may be incriminating.	*Challenges:* - Poor discovery. - Low awareness. - Unclear to users what exactly gets deleted where.	*Challenges:* - Low awareness. - High usability friction. - Foreign terms. - Modes can be viewed as shady.	*Challenges:* - Low understanding of cross-device actions. - May limit user access to tech.

→ Reported efficacy at maintaining privacy on shared devices.

Figure 1: Reported efficacy by participants in achieving their privacy goals on shared phones

Discussion

- What other regions of the world would you like to see studied like this?
- What would you study next (other than “other regions”)?

Thank you!